

CIHE
Crown Institute

AI SECURITY
Research Group

PhishLens: AI-Powered Phishing Email Detection Platform

A secure full-stack web application with explainable ML detection and role-based access control

Tandin Wangyel | Tashi Namgay | Gaki Palden | Melam Rabzang

Crown Institute of Higher Education | CIHE240943 | CIHE241207 | CIHE240539 | CIHE240648

BEST F1 SCORE

98.05%

Stacking Random Forest

DETECT PHISHING

EXPLAIN RISK

PROTECT USERS

BERT AND DISTILBERT

LLAMA MODEL

DEVSECOPS ARCHITECTURE

ABSTRACT

PhishLens is a secure full-stack platform that combines AI-assisted phishing email detection, explainable risk outputs, and role-based workflows for users, researchers, and administrators. The system uses React/Vite, Express, MongoDB, and FastAPI ML services. BERT, DistilBERT, and LLaMA models were trained on 18,000 emails and compared with five ensemble methods. The best method, Stacking Random Forest, achieved 98.44% accuracy and an F1 score of 0.9805.

INTRODUCTION

- Phishing emails exploit trust, urgency, fear, reward, and familiar brands.
- Rule-based filters can miss changing wording and new attack patterns.
- Secure design is needed because predictions, dashboards, and logs contain sensitive information.

PhishLens combines model evaluation with explainable detection, RBAC, 2FA, dataset workflows, and testing evidence.

OBJECTIVES

- Classify email content and explain suspicious indicators.
- Train and compare BERT, DistilBERT, and LLaMA on 18,000 emails.
- Combine models using five ensemble methods.
- Implement bcrypt, JWT, RBAC, and optional TOTP 2FA security.
- Support researcher and admin dashboards with activity logging.

DATASET AND METHODOLOGY

- 18,650 Kaggle emails were prepared, with 18,000 used for testing and model work.
- TF-IDF vectorisation and domain-specific features were engineered.
- Dataset split: 70% train, 15% validation, and 15% test.

1
DATA
Download and clean

2
FEATURES
TF-IDF plus domain features

3
TRAIN
BERT, DistilBERT, LLaMA

4
ENSEMBLE
Five strategies

5
EVALUATE
Accuracy, F1, precision, recall

SECURE SYSTEM ARCHITECTURE

React / Vite
Detector, auth, dashboards

Express API
JWT, RBAC, proxy, JSON responses

MongoDB
Users, datasets, predictions, logs

FastAPI ML
Predict, train, ensemble

Model Files
PKL files, vectorizers, notebooks, CSV

Design principle: the browser never calls the ML service directly. Express validates requests, enforces RBAC, stores audit records, and returns JSON-only responses.

SECURITY CONTROLS

- bcrypt password hashing and JWT login
- TOTP-based optional 2FA setup
- Role middleware for admin, researcher, and user
- CSV-only upload and request validation
- MongoDB operator sanitisation

ROLE DASHBOARDS

- User: submit emails and view predictions.
- Researcher: upload CSV datasets and compare model metrics.
- Admin: approve users, assign roles, and view platform logs.

HOW PHISHLENS IDENTIFIES PHISHING

Suspicious keyword analysis on 18,000 emails:

Reward / Greed

2972

Authority

1589

Action Demand

1153

Time Pressure

707

Threat / Fear

177

0.58
Legitimate urgency

0.90
Phishing urgency

INDIVIDUAL MODEL RESULTS

Model	Acc	Prec	Recall	F1
BERT	97.74%	95.86%	98.49%	97.15%
DistilBERT	97.70%	95.95%	98.30%	97.11%
LLaMA	98.07%	96.50%	98.68%	97.58%

5
EPOCHS

18k
EMAILS

LLaMA
BEST SINGLE MODEL

ENSEMBLE METHOD RESULTS

Method	Acc	F1
Hard Voting	98.04%	97.53%
Soft Voting	98.04%	97.53%
Weighted Voting	98.04%	97.53%
Stacking LR	98.11%	97.62%
Stacking RF	98.44%	98.05%

Best method: Stacking Random Forest achieved the highest F1 score of 0.9805 with precision 96.70% and recall 99.43%.

PERFORMANCE AND TESTING

- 22 of 22 unit tests passed for auth, register, login, JWT, and prediction flow.
- Locust load testing showed 0% failure under 50 users.
- OWASP ZAP scanning and activity logs support security validation.
- Prediction history and dataset metadata support auditability.

22/22
TESTS PASSED

0%
LOAD FAILURES

100+
LOG ENTRIES

CONCLUSION AND FUTURE WORK

PhishLens demonstrates a complete academic secure AI prototype: model comparison, ensemble learning, explainable prediction, secure role-based workflows, and repeatable testing evidence.

Future work includes production BERT and DistilBERT weights, SPF and DKIM intelligence, Docker Compose, CI/CD scanning, refresh tokens, password reset, and monitoring.

SECURE
JWT, RBAC, 2FA

INTELLIGENT
3 models, 5 ensembles

EXPLAINABLE
Indicators and confidence

RESEARCH READY
CSV upload and training

VALIDATED
Tests, Locust, ZAP

PhishLens | CIHE Secure AI Phishing Email Detection Project | May 2026

Detect threats. Explain risk. Protect users.

Supervised by Md. Ashraf Uddin | ashraf.uddin@cihe.edu.au